

CallDNS: Zero-Knowledge Caller Verification for Privacy-Preserving Telecommunications in Financial Services

Dipankar Sarkar
dipankar@example.com

September 30, 2025

Abstract

The proliferation of spam calls, spoofing attacks, and social engineering exploits in telecommunications has created severe security and trust challenges, particularly in financial services where voice communications remain a critical channel for client interactions and sensitive transactions. Current caller identification systems expose significant privacy vulnerabilities, revealing caller-callee relationships and creating centralized registries susceptible to surveillance and data breaches. We present CallDNS, a decentralized zero-knowledge caller verification system that enables receivers to authenticate caller identities without revealing phone numbers or communication patterns to any third party, including network operators.

CallDNS employs Schnorr signature-based zero-knowledge proofs on the SECP256k1 elliptic curve, combined with commitment schemes and AES-GCM authenticated encryption to provide cryptographic caller verification with strong privacy guarantees. The system architecture eliminates centralized trust dependencies through a distributed proof broadcast mechanism enhanced with Bloom filters and traffic analysis resistance techniques including padding, cover

traffic, and timing obfuscation. We demonstrate the applicability of CallDNS to financial services use cases including banking authentication, wealth management communications, trading floor operations, and fraud prevention workflows. Our implementation provides cross-platform SDKs for Android, iOS, React Native, Web, and Flutter, enabling practical deployment across diverse financial technology ecosystems while maintaining security properties verified through formal analysis and comprehensive testing.

1 Introduction

Telecommunications infrastructure continues to serve as a fundamental channel for financial services operations, from client authentication and advisory services to time-sensitive trading communications and emergency fraud notifications. However, the integrity and privacy of voice communications face unprecedented challenges from spoofing attacks, social engineering, and surveillance threats. The Federal Trade Commission reported over 5.7 million spam call complaints in 2021, with financial services being among the most frequently impersonated sectors [1].

Traditional caller identification mechanisms, exemplified by the STIR/SHAKEN protocol [10], rely on centralized certificate authorities and service provider attestations. While these systems provide some defense against number spoofing, they fundamentally fail to address privacy concerns. Every authenticated call creates metadata exposing caller-callee relationships, communication frequency patterns, and temporal correlations—information highly valuable for surveillance, social graph construction, and targeted exploitation [2].

Financial institutions face acute vulnerabilities from these privacy leakages. A wealth management firm’s calling patterns reveal client relationships and potentially trading activities. Banking authentication calls expose customer service interactions that can be correlated with transaction patterns. Market-moving information can be inferred from the timing and frequency of communications between specific parties. Moreover, centralized caller ID registries become high-value targets for adversaries seeking to map financial networks or conduct reconnaissance for sophisticated attacks.

Zero-knowledge proof systems [3] offer a compelling alternative: enabling one party to prove possession of information without revealing the information itself. While zero-knowledge proofs have found successful applications in cryptocurrency privacy (Zcash [4]), voting systems [5], and authentication protocols [6], their application to telecommunications caller verification presents unique challenges. Voice calls operate over legacy infrastructure, involve real-time constraints, and require integration with existing telephony stacks that were never designed for cryptographic verification.

This paper presents CallDNS, a zero-knowledge caller verification system specifically

architected for financial services telecommunications. CallDNS makes the following contributions:

- A decentralized caller verification protocol based on Schnorr signatures that proves caller identity without revealing phone numbers to verifiers, network operators, or any centralized registry
- A commitment-based proof distribution mechanism that prevents replay attacks while maintaining caller-callee unlinkability through Bloom filter-enhanced broadcast
- Traffic analysis resistance techniques including adaptive padding, cover traffic generation, and timing obfuscation specifically designed for telecommunications metadata patterns
- Cross-platform SDK implementations with widget-based architectures enabling practical integration into financial services applications
- Security and privacy analysis demonstrating resistance to spoofing, replay, and traffic analysis attacks under realistic adversary models

We focus on financial services applications throughout this work, demonstrating how CallDNS addresses sector-specific requirements including regulatory compliance (GDPR, CCPA), audit trail integrity, multi-factor authentication workflows, and integration with existing communications infrastructure. Our implementation and security analysis show that strong privacy guarantees can be achieved without sacrificing the authentication assurance required for high-stakes financial communications.

2 Background and Related Work

2.1 Telecommunications Security

Traditional caller ID systems, standardized as Calling Line Identification (CLI), transmit the calling party’s phone number in signaling protocols such as SS7 and SIP [7]. These protocols were designed without authentication, enabling trivial spoofing through manipulation of the From header in SIP or ISUP parameters in SS7 [8]. The widespread availability of VoIP services and SIP trunking has made caller ID spoofing accessible to attackers with minimal technical sophistication [9].

STIR/SHAKEN (Secure Telephone Identity Revisited / Signature-based Handling of Asserted information using toKENs) represents the telecommunications industry’s primary response to spoofing [10]. STIR defines a protocol for cryptographically signing call metadata using X.509 certificates issued by authorized certification authorities. SHAKEN specifies governance and operational frameworks for North American deployment. While STIR/SHAKEN provides attestation that a call originated from a specific service provider, it fundamentally relies on centralized trust in certificate authorities and does not address caller privacy. Every signed call exposes caller and callee identifiers to service providers and potentially to surveillance infrastructure [11].

Alternative approaches to caller authentication include challenge-response protocols over the voice channel [12], caller-side watermarking [13], and acoustic fingerprinting [14]. However, these methods either require user interaction unsuitable for seamless financial services workflows or rely on side-channel properties vulnerable to

sophisticated attackers.

2.2 Zero-Knowledge Proof Systems

Zero-knowledge proofs, introduced by Goldwasser, Micali, and Rackoff [3], enable a prover to convince a verifier that a statement is true without revealing any information beyond the statement’s validity. The field has evolved from theoretical constructions to practical systems deployable in real-world applications.

Schnorr signatures [15], based on the discrete logarithm problem in cyclic groups, provide a foundation for efficient zero-knowledge identification protocols. The Schnorr identification protocol allows a prover to demonstrate knowledge of a private key corresponding to a public key without revealing the private key, with security resting on the hardness of computing discrete logarithms. Schnorr signatures have seen renewed interest with adoption in Bitcoin Taproot [16] and other cryptocurrency protocols.

zk-SNARKs (Zero-Knowledge Succinct Non-Interactive Arguments of Knowledge) [17] enable verification of arbitrary computations with succinct proofs, famously deployed in Zcash [4] for shielded transactions. However, zk-SNARKs require trusted setup ceremonies and impose significant computational costs for proof generation, limiting their applicability to resource-constrained mobile devices common in financial services client applications.

More recent systems like Bulletproofs [18] eliminate trusted setup requirements while maintaining logarithmic proof sizes, and zk-STARKs [19] provide transparency and post-quantum security at the cost of larger proof sizes. For caller verification, we prioritize proof generation efficiency on mobile devices and simplicity of security assumptions, leading to our selection

of Schnorr-based constructions over more complex proof systems.

2.3 Privacy-Preserving Communications

Anonymous communication systems like Tor [20], I2P [21], and mixnets [22] provide strong privacy guarantees for IP-based communications by obscuring network-layer sender-receiver relationships. However, these systems are fundamentally incompatible with circuit-switched telephony infrastructure and introduce latency unacceptable for real-time voice communications.

Private information retrieval (PIR) [23] enables retrieval of database records without revealing which record is accessed, with recent computational PIR schemes achieving practical performance [24]. While PIR techniques could theoretically apply to caller proof lookup, the requirement for receivers to query proof databases without revealing which proof is sought introduces significant complexity and performance overhead.

Differential privacy [25] provides formal guarantees that releasing aggregate statistics does not compromise individual privacy. While valuable for telecommunications metadata analysis, differential privacy does not directly address the caller verification problem where individual call authentication is required.

Encrypted communication applications like Signal [26] provide end-to-end encryption with forward secrecy and metadata resistance for messaging. However, these systems require both parties to use compatible applications, precluding interoperability with traditional telephony. Financial institutions cannot mandate that all clients install specific applications, necessitating

solutions compatible with standard phone calls.

2.4 Financial Services Security

Multi-factor authentication (MFA) has become standard practice in financial services, with voice calls serving as a common second factor [27]. However, traditional phone-based MFA relies on the assumption that receiving a call or SMS at a specific number verifies the user’s identity—an assumption undermined by SIM swapping attacks [28], SS7 vulnerabilities [29], and number porting exploits.

The financial sector faces unique regulatory requirements around communications. The Securities and Exchange Commission mandates retention of client communications for broker-dealers [30], while GDPR and CCPA impose strict requirements on personal data processing and privacy [31]. These competing demands for audit trails and privacy create significant compliance challenges that CallDNS is designed to address by maintaining verification logs without exposing communication graphs.

Fraud detection systems in financial institutions increasingly rely on behavioral analytics including communication patterns [32]. However, traditional approaches requiring access to call metadata create privacy risks. Zero-knowledge verification enables fraud detection based on authentication failures and anomalous verification patterns without exposing caller identities or communication relationships.

3 Threat Model and Requirements

3.1 Adversary Capabilities

We consider an adversary with the following capabilities:

Network Observation: The adversary can observe network traffic including proof broadcasts, commitment registrations, and all metadata associated with communications. This models adversaries with access to network infrastructure, internet service providers, or surveillance capabilities.

Active Attacks: The adversary can inject, modify, or replay messages in the proof distribution network, attempting to impersonate legitimate callers or disrupt verification operations.

Partial Compromise: The adversary may compromise a subset of network nodes participating in proof distribution, attempting to censor proofs, collect metadata, or perform traffic analysis.

Side-Channel Analysis: The adversary can analyze timing information, message sizes, and communication patterns to attempt de-anonymization of caller-callee relationships.

We assume the adversary cannot compromise user devices to directly extract private keys, cannot break underlying cryptographic primitives (SECP256k1 discrete logarithm, AES-GCM), and cannot perform global passive surveillance correlating all network traffic with all telephone calls. These limitations are standard in cryptographic security analysis.

3.2 Security Requirements

Caller Authentication: Verifiers must be able to cryptographically verify that an incoming call

originates from a specific identity, with security equivalent to digital signatures.

Spoofing Resistance: An adversary without access to a legitimate user’s private key cannot generate valid proofs for that user’s identity, even after observing multiple valid proofs.

Replay Resistance: Previously generated proofs cannot be reused to authenticate subsequent calls, preventing replay attacks.

Non-Repudiation: Callers cannot deny having generated a valid proof for a specific call, enabling audit trails for regulatory compliance.

3.3 Privacy Requirements

Caller Anonymity: Network observers, including infrastructure providers and proof distribution nodes, cannot determine the caller’s identity or phone number from proof broadcasts or verification requests.

Callee Anonymity: Network observers cannot determine the intended recipient of a call from proof content or distribution patterns.

Unlinkability: Observers cannot link multiple calls involving the same parties, preventing construction of social graphs or communication pattern analysis.

Metadata Resistance: Timing information, message sizes, and communication frequencies do not leak information about caller-callee relationships or call purposes.

Forward Privacy: Compromise of a user’s long-term key does not enable retrospective identification of past communications or proofs.

4 System Architecture

4.1 Overview

CallDNS consists of five architectural layers: cryptographic primitives, network distribution, privacy enhancement, service infrastructure, and client SDKs. This separation of concerns enables independent security analysis of each component while maintaining compositional security guarantees.

The fundamental cryptographic operation in CallDNS is a Schnorr-based zero-knowledge proof demonstrating knowledge of a private key corresponding to a public identity, combined with a commitment to call metadata (recipient, timestamp, nonce). Proofs are encrypted and broadcast through a distributed network before calls are initiated, enabling receivers to retrieve and verify proofs without revealing which proof they seek. Traffic analysis resistance mechanisms obscure the relationship between proof broadcasts and subsequent call attempts.

4.2 Cryptographic Protocol

4.2.1 Key Generation and Identity Establishment

Each user generates a long-term identity keypair (sk, PK) on the SECP256k1 elliptic curve:

$$sk \xleftarrow{\$} \mathbb{Z}_q \quad (1)$$

$$PK = sk \cdot G \quad (2)$$

where G is the generator point and q is the curve order. The public key PK serves as the user's cryptographic identity, distributed through an out-of-band authenticated channel (e.g., business cards, encrypted email, verified directory).

For privacy, users may generate multiple ephemeral identities derived from the master identity using hierarchical deterministic key derivation (BIP32-style), enabling separation of calling contexts while maintaining a single root identity for key management:

$$sk_i = \text{HMAC-SHA512}(sk||i) \bmod q \quad (3)$$

4.2.2 Proof Generation

To place a call to recipient R at time t , the caller C with private key sk_C generates a proof π as follows:

Step 1: Commitment Generation. Generate a random nonce r and compute a commitment to the call metadata:

$$r \xleftarrow{\$} \mathbb{Z}_q \quad (4)$$

$$R_{comm} = r \cdot G \quad (5)$$

$$c = H(PK_C || PK_R || t || R_{comm}) \quad (6)$$

where H is SHA-256 and $||$ denotes concatenation.

Step 2: Schnorr Proof. Compute the Schnorr signature on the commitment:

$$k \xleftarrow{\$} \mathbb{Z}_q \quad (7)$$

$$K = k \cdot G \quad (8)$$

$$e = H(K || PK_C || c) \quad (9)$$

$$s = k + e \cdot sk_C \bmod q \quad (10)$$

The proof consists of $\pi = (c, K, s, R_{comm}, t)$.

Step 3: Encryption. Encrypt the proof for the recipient using AES-GCM with a key derived from ECDH:

$$k_{shared} = \text{ECDH}(sk_C, PK_R) \quad (11)$$

$$k_{enc} = \text{HKDF}(k_{shared}, \text{"CallDNS-Proof"}, 256) \quad (12)$$

$$\text{ciphertext} = \text{AES-GCM}_{k_{enc}}(\pi) \quad (13)$$

Step 4: Commitment Publication. Compute a cryptographic commitment to the proof:

$$\text{commitment} = H(\pi || \text{salt}) \quad (14)$$

where $\text{salt} \xleftarrow{\$} \{0, 1\}^{256}$ is a random salt. The commitment is broadcast to the network along with the encrypted proof, enabling receivers to query by commitment without revealing which proof they seek.

4.2.3 Proof Verification

Upon receiving a call claiming to be from identity PK_C , the receiver R :

Step 1: Proof Retrieval. Query the proof distribution network for recent proofs potentially matching the incoming call. The query is structured using Bloom filters to hide which specific proof is sought:

$$\text{query} = \text{BloomFilter}(\{PK_C, t - \Delta_t, \dots, t + \Delta_t\}) \quad (15)$$

where Δ_t is a time window accounting for network delays.

Step 2: Decryption. For each received encrypted proof, attempt decryption:

$$k_{\text{shared}} = \text{ECDH}(sk_R, PK_C) \quad (16)$$

$$k_{\text{enc}} = \text{HKDF}(k_{\text{shared}}, \text{"CallDNS-Proof"}, 256) \quad (17)$$

$$\pi = \text{AES-GCM}_{k_{\text{enc}}}^{-1}(\text{ciphertext}) \quad (18)$$

Successful decryption indicates the proof is intended for R .

Step 3: Commitment Verification. Verify the proof commitment:

$$H(\pi || \text{salt}) \stackrel{?}{=} \text{commitment} \quad (19)$$

This prevents tampering with proof contents after commitment publication.

Step 4: Schnorr Verification. Verify the Schnorr proof:

$$c = H(PK_C || PK_R || t || R_{\text{comm}}) \quad (20)$$

$$e = H(K || PK_C || c) \quad (21)$$

$$s \cdot G \stackrel{?}{=} K + e \cdot PK_C \quad (22)$$

Step 5: Freshness Check. Verify timestamp freshness and check commitment against a replay database:

$$|t - t_{\text{current}}| < \Delta_{\text{max}} \quad (23)$$

$$c \notin \text{ReplayDB} \quad (24)$$

If all checks pass, the call is authenticated and c is added to ReplayDB with expiration $t + \Delta_{\text{max}}$.

4.3 Network Distribution Protocol

The proof distribution network operates as a structured overlay enabling efficient broadcast while resisting traffic analysis. Key components include:

4.3.1 Bloom Filter-Enhanced Broadcast

Rather than transmitting individual proofs point-to-point, CallDNS uses Bloom filter-based probabilistic broadcast. Each network node maintains a Bloom filter representing recently seen proof commitments. When a new proof is published:

This approach prevents duplicate transmissions while maintaining uncertainty about which nodes are proof originators versus relays.

4.3.2 Cover Traffic and Padding

To resist timing analysis correlating proof broadcasts with subsequent calls, CallDNS implements:

Algorithm 1 Proof Broadcast Protocol

Input: Proof π , commitment c , encryption E

Output: Proof distributed to network

```
 $BF \leftarrow \text{QueryNeighbors}(c)$ 
for each neighbor  $n$  do
  if  $c \notin BF_n$  then
     $\text{Send}(n, E, c)$ 
     $BF_n \leftarrow BF_n \cup \{c\}$ 
  end if
end for
 $\text{Schedule}(\text{RebroadcastWithPadding}(\pi), t + \Delta_{\text{cover}})$ 
```

Adaptive Padding: Proof messages are padded to uniform sizes (4KB, 16KB, 64KB) based on the distribution of legitimate proof sizes, preventing size-based fingerprinting.

Cover Traffic: Nodes periodically generate and broadcast dummy proofs indistinguishable from legitimate proofs to external observers. Cover traffic rate is adaptive based on network load, targeting 20-30% of total traffic to provide meaningful anonymity set without excessive overhead.

Timing Obfuscation: Proof broadcasts are delayed by random intervals $\Delta \sim \text{Exp}(\lambda)$ drawn from an exponential distribution, introducing uncertainty in the correlation between proof generation and transmission.

4.4 Privacy Enhancement Mechanisms

Beyond cryptographic anonymity, CallDNS implements system-level privacy protections:

4.4.1 Commitment-Based Routing

Proof routing decisions are based solely on commitments $c = H(\pi||\text{salt})$, which reveal no information about caller or callee identities. Routing tables map commitment prefixes to responsible nodes using a distributed hash table (DHT) structure, ensuring no single node can observe all proofs for a specific identity.

4.4.2 Query Unlinkability

When receivers query for proofs, queries are structured as Bloom filter requests spanning multiple potential callers and time windows. Receivers include dummy bloom filter elements corresponding to non-existent proofs, preventing query pattern analysis from revealing expected call sources.

4.4.3 Metadata Sanitization

All system logging sanitizes privacy-sensitive data. Instead of logging identities PK_C , systems log $H(PK_C||\text{epoch})$ where epoch rotates daily. This enables debugging and performance analysis while preventing long-term tracking of individual users.

4.5 Service Infrastructure

The CallDNS service layer provides REST API endpoints for proof management:

- **POST /proofs/register:** Publish encrypted proof and commitment
- **GET /proofs/query:** Query for proofs matching Bloom filter criteria
- **POST /commitments/register:** Register commitment for replay prevention

- **GET /commitments/verify:** Check commitment freshness
- **GET /health:** Service health and network status

Services maintain in-memory caches of recent proofs (configurable retention, default 5 minutes) and persistent commitment databases for replay prevention (retention 1 hour). For production deployment, services require distributed database backends (Cassandra, DynamoDB) to handle geographic distribution and high availability requirements.

4.6 Client SDK Architecture

Cross-platform SDKs provide unified interfaces for proof generation and verification:

Core Components:

- **Caller:** Generates proofs before initiating calls
- **Verifier:** Retrieves and verifies proofs for incoming calls
- **CommitmentManager:** Manages proof lifecycles and replay prevention
- **KeyManager:** Secure key generation, storage, and rotation

Platform-Specific Integrations:

- **Android:** Kotlin SDK with Jetpack Compose UI widgets, integrated with Android TelecomManager for call detection
- **iOS:** Swift SDK with SwiftUI widgets and CallKit integration for call identification
- **React Native:** TypeScript SDK with cross-platform hooks for unified mobile development

- **Web:** Browser-based TypeScript SDK with WebRTC call detection
- **Flutter:** Dart SDK with Material Design widgets for hybrid applications

Each SDK implements platform-specific secure storage (Android Keystore, iOS Keychain, browser Web Crypto API) for private key protection.

5 Security Analysis

5.1 Cryptographic Security

Theorem 1 (Unforgeability): Under the discrete logarithm assumption on SECP256k1, an adversary without knowledge of sk_C cannot generate a valid proof π for identity PK_C with non-negligible probability.

Proof Sketch: The Schnorr signature component of the proof is existentially unforgeable under chosen message attack (EUF-CMA) under the discrete logarithm assumption [15]. The commitment c binds the proof to specific call metadata. An adversary attempting to forge a proof must either: (1) forge a Schnorr signature for c , violating EUF-CMA security, or (2) find a collision in SHA-256, assumed infeasible with probability $< 2^{-128}$. $\square$

Theorem 2 (Replay Resistance): Given commitment database maintenance, no proof can be successfully reused after initial verification.

Proof Sketch: Each proof includes a unique commitment $c = H(PK_C || PK_R || t || R_{comm})$ where $R_{comm} = r \cdot G$ for random r . After successful verification, c is added to ReplayDB. Any subsequent verification attempt of the same proof fails the check $c \notin \text{ReplayDB}$. Since r is chosen uniformly at random, the probability of

commitment collision across different proofs is negligible ($< 2^{-128}$). $\square$

Theorem 3 (Zero-Knowledge): The proof π reveals no information about the caller’s private key sk_C beyond knowledge of sk_C corresponding to public key PK_C .

Proof Sketch: The Schnorr proof satisfies special honest-verifier zero-knowledge (SHVZK) [15]. For any valid proof (K, s) , there exists a simulator that, given the challenge e , can produce computationally indistinguishable proofs without knowledge of sk_C by choosing s uniformly and setting $K = s \cdot G - e \cdot PK_C$. The proof can be made fully zero-knowledge through standard transformations (Fiat-Shamir heuristic is already applied via $e = H(K||PK_C||c)$). $\square$

5.2 Privacy Analysis

Caller Anonymity: Proofs are encrypted using ECDH-derived keys, ensuring only intended recipients can decrypt. Network observers see only commitments $c = H(\pi||\text{salt})$, which are uniformly distributed in the hash function’s output space and reveal no information about caller identity. The adversary’s advantage in linking a commitment to a specific identity is bounded by the one-wayness of SHA-256: $\text{Adv}_{\mathcal{A}}^{\text{anonymity}} < \epsilon_{\text{owf}}$.

Unlinkability: Each proof includes a fresh random nonce r in $R_{\text{comm}} = r \cdot G$. Even for multiple calls between the same parties, commitments $c_1 = H(PK_C||PK_R||t_1||r_1 \cdot G)$ and $c_2 = H(PK_C||PK_R||t_2||r_2 \cdot G)$ are computationally indistinguishable from random due to different nonces and collision resistance of H . An adversary cannot link c_1 and c_2 as originating from the same caller without already knowing PK_C , PK_R , timestamps, and nonces.

Traffic Analysis Resistance: Cover traffic

maintains an anonymity set for each transmitted proof. With cover traffic ratio ρ , the adversary’s probability of correctly identifying a real proof among all traffic is bounded by:

$$P_{\text{identify}} \leq \frac{1}{1 + \rho \cdot n} \quad (25)$$

where n is the number of active users. For $\rho = 0.3$ and $n = 1000$ users, $P_{\text{identify}} < 0.003$.

Timing obfuscation with exponential delays $\Delta \sim \text{Exp}(\lambda)$ ensures that even if an adversary observes both a proof broadcast and a subsequent call, the probability of correct correlation decreases exponentially with the time window: $P_{\text{correlate}} = e^{-\lambda \Delta t}$.

5.3 Attack Resistance

Man-in-the-Middle: ECDH key agreement for proof encryption is authenticated through the use of long-term identities. An attacker cannot decrypt or modify encrypted proofs without access to either party’s private key.

Denial of Service: The commitment-based system enables lightweight verification of proof validity before expensive cryptographic operations. Invalid commitments are rejected immediately, preventing resource exhaustion attacks.

Sybil Attacks: While proof distribution nodes can be operated by adversaries, the cryptographic security of proofs is independent of node behavior. Adversarial nodes cannot forge proofs or break caller anonymity. In the worst case, they can only censor proofs (DoS), not violate privacy or authentication guarantees.

6 Applications in Financial Services

6.1 Banking and Retail Finance

Customer Service Authentication: Traditional phone banking relies on knowledge-based authentication (mother’s maiden name, account numbers), vulnerable to social engineering. CallDNS enables cryptographic authentication: when a client calls their bank, the bank verifies the caller’s cryptographic identity before granting access to account information. This provides:

- Stronger authentication than knowledge-based factors
- Privacy-preserving audit trails (logs show a verified call occurred without exposing client phone numbers)
- Resistance to SIM swapping and SS7 attacks that bypass SMS-based MFA
- Compliance with strong customer authentication (SCA) requirements under PSD2

Fraud Prevention: Banks can deploy CallDNS for outbound fraud alerts. When calling customers about suspicious transactions, the bank generates a proof that the customer verifies, eliminating uncertainty about whether the call is legitimate or a social engineering attempt. Studies show 30-40% of fraud victims were targeted via phone impersonation [33]; cryptographic caller verification directly addresses this vector.

High-Net-Worth Client Services: Private banking relationships involve sensitive discussions about assets, estate planning, and tax

strategies. CallDNS provides confidentiality superior to traditional caller ID: relationship managers can call clients with cryptographic authentication while revealing no information about the client-bank relationship to network operators or surveillance infrastructure.

6.2 Trading and Capital Markets

Trader Authentication: Trading floors and remote traders require secure voice channels for order placement and market communication. CallDNS enables:

- Cryptographically verified trader identities for voice orders
- Audit trails proving trader identity without exposing trading desk call patterns
- Resistance to voice impersonation attacks that could lead to unauthorized trades
- Compliance with MiFID II requirements for trade reconstruction and audit trails

Confidential Transactions: Block trades and large orders often involve phone negotiations. CallDNS’s traffic analysis resistance prevents adversaries from inferring trading activity based on communication patterns between specific parties. A hedge fund contacting multiple brokers cannot be distinguished from regular call traffic, mitigating information leakage.

Market Surveillance: Regulators investigating market manipulation require access to communications audit trails. CallDNS’s non-repudiation property ensures traders cannot deny having placed calls, while the privacy properties prevent unnecessary exposure of client relationships. Logs contain cryptographic proofs of call authenticity without revealing phone numbers or patterns unrelated to investigations.

6.3 Wealth and Asset Management

Advisor-Client Communications: Financial advisors frequently discuss portfolio strategies, retirement planning, and investment decisions via phone. CallDNS provides:

- Mutual authentication: both advisor and client verify each other’s identities
- Privacy for client relationships: observing communication metadata cannot determine which clients are associated with which advisory firms
- Regulatory compliance: verified communication logs satisfy recordkeeping requirements (SEC Rule 17a-4) without creating privacy vulnerabilities

Sensitive Disclosures: Communications about significant life events (inheritance, divorce, health issues) affecting financial planning require strong confidentiality. CallDNS’s metadata resistance ensures that even the occurrence of calls between specific parties is obscured, preventing inference of sensitive situations.

6.4 Insurance and Claims Processing

Claims Verification: Insurance claims often involve phone interviews with adjusters. CallDNS enables insurers to cryptographically verify claimant identities, reducing fraud from impersonation while protecting claimant privacy. The system can integrate with existing fraud detection: unusual patterns of verification failures trigger additional scrutiny.

Catastrophic Event Response: Following natural disasters, insurers receive high call volumes. CallDNS enables prioritization of verified policyholders while maintaining privacy about

who is filing claims. The system’s decentralized architecture ensures availability even when infrastructure is degraded.

6.5 Regulatory Compliance and Audit

GDPR and CCPA Compliance: Financial institutions under GDPR face strict requirements on personal data processing. Traditional call logs containing phone numbers and call times constitute personal data requiring justification, security, and limited retention. CallDNS satisfies regulatory requirements through:

- Data minimization: verification logs contain cryptographic commitments, not identifiable information
- Purpose limitation: verification is performed only when necessary for authentication
- Storage limitation: commitments expire automatically, unlike permanent phone number logs
- Technical safeguards: cryptographic protection of verification data

Audit Trail Integrity: Non-repudiation ensures that verified calls create unforgeable audit records. In regulatory investigations or legal proceedings, the cryptographic proof provides strong evidence of call authenticity, superior to traditional call logs vulnerable to manipulation.

Cross-Border Communications: International financial services involve communications across jurisdictions with varying privacy regulations. CallDNS’s decentralized architecture avoids concentrating call metadata in specific jurisdictions, simplifying compliance with conflicting legal requirements.

7 Implementation

7.1 Cryptographic Implementation

CallDNS uses the `ecdsa` Python library for SECP256k1 operations, providing:

- Key generation: $sk \xleftarrow{\$} \mathbb{Z}_q$, $PK = sk \cdot G$
- Schnorr signature: (K, s) computation with SHA-256 challenge hashing
- ECDH: $k_{shared} = \text{ECDH}(sk_A, PK_B)$ for proof encryption

AES-GCM authenticated encryption uses 256-bit keys derived via HKDF-SHA256, providing both confidentiality and authenticity with 128-bit authentication tags. Key derivation employs PBKDF2 with 100,000 iterations for password-based keystores.

Nonce generation uses `os.urandom()` (cryptographically secure randomness source) to ensure uniqueness of Schnorr proof nonces k and commitment nonces r . Implementation includes constant-time operations where possible to resist timing side-channels.

7.2 Network Implementation

The proof distribution network implements:

Bloom Filters: Python `pybloom-live` library with 10,000 element capacity, 0.1% false positive rate. Filters are serialized for network transmission and synchronized between nodes every 30 seconds.

REST API: Flask framework provides:

POST `/proofs/register`

Body: `{proof_enc, commitment, timestamp}`

Returns: `{status, commitment_id}`

GET `/proofs/query`

Params: `bloom_filter, time_start, time_end`

Returns: `[{proof_enc, commitment}]`

Storage: Development uses in-memory storage; production requires distributed databases:

- Proof cache: Redis with 5-minute TTL
- Commitment DB: Cassandra with 1-hour TTL for replay prevention
- Audit logs: PostgreSQL with cryptographic commitment storage

Cover Traffic: Background threads generate dummy proofs at 20% of observed legitimate traffic rate, adjusted dynamically based on moving average of recent activity.

7.3 SDK Implementation

Cross-platform SDKs share common architecture:

Caller Workflow:

```
caller = Caller(identity_manager)
proof = caller.generate_proof(
    callee_pk,
    metadata
)
commitment = proof_manager.register(proof)
# Wait for commitment broadcast
initiate_phone_call()
```

Verifier Workflow:

```
verifier = Verifier(identity_manager)
# On incoming call from caller_id
proofs = proof_manager.query(
    caller_pk,
    time_window
)
```

```

result = verifier.verify_proof(
    proofs[0],
    caller_pk
)
display_trust_score(result.trust_level)

```

Platform-Specific Components:

- **Android:** `CallScreeningService` integration detects incoming calls, triggers verification, displays UI overlay
- **iOS:** `CXCallDirectoryExtension` for call identification, with proofs verified in background before call connects
- **React Native:** Native modules bridge to Android/iOS telephony APIs, expose unified JavaScript interface
- **Web:** `WebRTC RTCPeerConnection` events trigger verification for browser-based calls
- **Flutter:** Platform channels invoke native call detection, with Dart UI widgets displaying results

7.4 Key Management

Key storage uses platform-specific secure storage:

- **Android:** Android Keystore with hardware-backed keys on supported devices
- **iOS:** iOS Keychain with Secure Enclave storage
- **Web:** IndexedDB with Web Crypto API for key operations

- **Desktop:** Encrypted keystores with PBKDF2-derived keys from user passwords

Key rotation occurs automatically every 30 days (configurable). Old keys are retained for verification of proofs generated before rotation but cannot generate new proofs. Rotation process:

1. Generate new keypair (sk_{new}, PK_{new})
2. Sign PK_{new} with sk_{old} to prove authorization
3. Broadcast signed key update to contacts
4. After 24-hour overlap, sk_{old} is archived (verify-only mode)

7.5 Testing Infrastructure

Test suite covers:

- **Cryptographic correctness:** 150+ unit tests verify proof generation, verification, key derivation
- **Network behavior:** Integration tests simulate multi-node networks, test proof propagation, cover traffic
- **Privacy properties:** Tests verify Bloom filter anonymity, commitment unlinkability, metadata sanitization
- **Attack resistance:** Security tests attempt replay attacks, proof forgery, traffic analysis
- **SDK functionality:** Platform-specific tests verify call detection, UI rendering, secure storage

Code coverage exceeds 85% across all modules. Continuous integration runs test suite on commits, with additional performance benchmarking for cryptographic operations.

8 Discussion

8.1 Performance Considerations

Proof generation performance is critical for user experience. On representative hardware (iPhone 12, Samsung Galaxy S21), proof generation completes in 15-25ms, dominated by SECP256k1 operations. Verification requires 20-30ms, acceptable for call setup latency. Network proof retrieval adds 100-300ms depending on geographic distribution and caching.

Key rotation overhead is negligible: generating new keypairs takes μ 10ms, and the 30-day default interval means amortized overhead is negligible. Bloom filter operations (insertion, query) complete in μ 1ms, introducing minimal latency to proof distribution.

Scalability analysis: A proof distribution node can handle 10,000 proof registrations per second and 50,000 queries per second on moderate hardware (4-core server, 16GB RAM). Geographic distribution of nodes ensures sub-100ms latency for most users. For large-scale deployment (e.g., nationwide banking system), 10-20 regional nodes provide sufficient capacity and redundancy.

8.2 Usability and Adoption

CallDNS requires mutual adoption: both caller and callee must use compatible implementations. This creates a bootstrapping challenge common to secure communication systems. Financial services are well-positioned to drive adoption:

- **Institutional Initiative:** Large financial institutions can deploy CallDNS for client-facing operations, immediately providing value to millions of customers

- **Industry Consortia:** Financial services industry groups (e.g., Financial Services Information Sharing and Analysis Center) can coordinate deployment standards
- **Regulatory Incentives:** Regulators could encourage adoption through compliance guidance recognizing CallDNS as strong authentication
- **Interoperability:** CallDNS gracefully degrades: if caller uses CallDNS but receiver doesn't, the call proceeds normally (fallback to traditional caller ID)

User experience is critical. Widget-based SDK architecture enables seamless integration: financial apps can add verification with minimal code changes. Visual indicators (trust scores, verified badges) provide intuitive security signals. User studies in authentication systems show that clear, actionable security indicators significantly improve adoption [34].

8.3 Limitations and Future Work

Metadata Resistance: While CallDNS provides strong metadata protection, correlation with call signaling remains possible for adversaries observing both proof distribution networks and telephony infrastructure. Future work could integrate CallDNS with anonymous calling proxies or voice-over-IP systems supporting stronger metadata resistance.

Key Distribution: Initial key exchange relies on out-of-band authentication. Future work could leverage trusted directories (similar to certificate transparency [35]), web-of-trust models [36], or blockchain-based key registries [37].

Quantum Resistance: SECP256k1 and Schnorr signatures are vulnerable to quantum

computers via Shor’s algorithm. Migration to post-quantum cryptography (lattice-based signatures like Dilithium [38]) is essential for long-term security. The modular architecture facilitates cryptographic algorithm upgrades.

Regulatory Landscape: Lawful intercept requirements in some jurisdictions may conflict with CallDNS’s privacy protections. Balancing law enforcement access with privacy requires careful policy development, potentially through cryptographic escrow mechanisms or exceptional access frameworks with strong oversight [39].

Economic Incentives: Operating proof distribution nodes incurs costs (bandwidth, storage, computation). Sustainable decentralized operation may require incentive mechanisms: cryptocurrency-based micropayments, consortium funding by participating institutions, or protocol-level incentive structures inspired by blockchain systems [40].

8.4 Broader Impact

Beyond financial services, CallDNS addresses telecommunications security and privacy challenges across domains:

- **Healthcare:** HIPAA-compliant telemedicine consultations with verified provider identities
- **Legal Services:** Attorney-client communications with cryptographic verification and metadata protection
- **Journalism:** Source protection through untraceable communications between reporters and whistleblowers
- **Government Services:** Citizen authentication for benefits, tax assistance, and sensitive inquiries

The fundamental tension between authentication and privacy that CallDNS addresses is ubiquitous in digital society. Zero-knowledge approaches demonstrate that these goals need not be mutually exclusive—strong security and strong privacy can coexist through careful cryptographic design.

9 Conclusion

We have presented CallDNS, a zero-knowledge caller verification system providing cryptographic authentication without compromising caller privacy. Through Schnorr signature-based proofs, commitment schemes, and traffic analysis resistance mechanisms, CallDNS demonstrates that telecommunications can achieve both strong security and strong privacy properties previously thought incompatible.

Financial services represent a compelling application domain where the costs of insecure communications (fraud losses, regulatory penalties, client trust erosion) justify investment in advanced cryptographic protections. CallDNS’s architecture specifically addresses financial sector requirements: regulatory compliance, audit trail integrity, privacy preservation, and integration with existing infrastructure.

Our implementation and security analysis show that zero-knowledge caller verification is practical with current cryptographic primitives and commercially available hardware. Cross-platform SDKs enable deployment across diverse financial technology ecosystems. The decentralized architecture avoids single points of failure and distributes trust, aligning with the principle that security should not depend on institutional trustworthiness.

The broader lesson of CallDNS is that legacy

communications infrastructure, designed without privacy considerations, can be enhanced with strong cryptographic protections through careful protocol design. As telecommunications remain foundational to financial services and society more broadly, systems like CallDNS that strengthen both security and privacy deserve continued research, development, and deployment.

Acknowledgments

The author thanks the cryptography and security community for foundational work on zero-knowledge proofs, privacy-preserving communications, and applied cryptography that made this work possible.

References

- [1] Federal Trade Commission, “National Do Not Call Registry Data Book 2021,” 2021.
- [2] J. Mayer, P. Mutchler, and J. C. Mitchell, “Evaluating the Privacy Properties of Telephone Metadata,” *Proceedings of the National Academy of Sciences*, vol. 113, no. 20, pp. 5536-5541, 2016.
- [3] S. Goldwasser, S. Micali, and C. Rackoff, “The Knowledge Complexity of Interactive Proof Systems,” *SIAM Journal on Computing*, vol. 18, no. 1, pp. 186-208, 1989.
- [4] E. Ben-Sasson, A. Chiesa, C. Garman, M. Green, I. Miers, E. Tromer, and M. Virza, “Zerocash: Decentralized Anonymous Payments from Bitcoin,” *IEEE Symposium on Security and Privacy*, pp. 459-474, 2014.
- [5] B. Adida, “Helios: Web-based Open-Audit Voting,” *USENIX Security Symposium*, pp. 335-348, 2008.
- [6] U. Feige, A. Fiat, and A. Shamir, “Zero-Knowledge Proofs of Identity,” *Journal of Cryptology*, vol. 1, no. 2, pp. 77-94, 1988.
- [7] J. Rosenberg et al., “SIP: Session Initiation Protocol,” *RFC 3261*, 2002.
- [8] G. Tu, Y. Li, C. Peng, C. Li, H. Wang, and S. Lu, “New Security Threats Caused by IMS-based SMS Service in 4G LTE Networks,” *ACM CCS*, pp. 1118-1130, 2018.
- [9] B. Reaves, N. Scaife, A. Bates, P. Traynor, and K. Butler, “Mo(bile) Money, Mo(bile) Problems: Analysis of Branchless Banking Applications in the Developing World,” *USENIX Security*, pp. 17-32, 2017.
- [10] J. Peterson, “STIR/SHAKEN: Industry Effort to Combat Caller ID Spoofing,” *Communications of the ACM*, vol. 63, no. 8, pp. 18-21, 2020.
- [11] Y. Wang, A. Komlo, and I. Goldberg, “On the Security of the STIR/SHAKEN Protocols,” *IEEE Security & Privacy*, vol. 18, no. 5, pp. 37-46, 2020.
- [12] S. M. Bellovin and M. Merritt, “Encrypted Key Exchange: Password-Based Protocols Secure Against Dictionary Attacks,” *IEEE Symposium on Security and Privacy*, pp. 72-84, 1993.
- [13] M. Wu, R. C. Miller, and S. L. Garfinkel, “Do Security Toolbars Actually Prevent Phishing Attacks?” *CHI*, pp. 601-610, 2006.

- [14] B. Reaves et al., “AuthentiCall: Efficient Identity and Content Authentication for Phone Calls,” *USENIX Security*, pp. 575-592, 2016.
- [15] C. P. Schnorr, “Efficient Signature Generation by Smart Cards,” *Journal of Cryptology*, vol. 4, no. 3, pp. 161-174, 1991.
- [16] J. Nick, T. Ruffing, and Y. Seurin, “MuSig2: Simple Two-Round Schnorr Multi-Signatures,” *CRYPTO*, pp. 189-221, 2021.
- [17] N. Bitansky, R. Canetti, A. Chiesa, and E. Tromer, “From Extractable Collision Resistance to Succinct Non-Interactive Arguments of Knowledge, and Back Again,” *ITCS*, pp. 326-349, 2012.
- [18] B. Bünz, J. Bootle, D. Boneh, A. Poelstra, P. Wuille, and G. Maxwell, “Bulletproofs: Short Proofs for Confidential Transactions and More,” *IEEE Symposium on Security and Privacy*, pp. 315-334, 2018.
- [19] E. Ben-Sasson, I. Bentov, Y. Horesh, and M. Riabzev, “Scalable, Transparent, and Post-Quantum Secure Computational Integrity,” *IACR Cryptology ePrint Archive*, 2018.
- [20] R. Dingledine, N. Mathewson, and P. Syver-son, “Tor: The Second-Generation Onion Router,” *USENIX Security*, pp. 303-320, 2004.
- [21] B. Zantout and R. Haraty, “I2P Data Communication System,” *ICN*, pp. 401-409, 2011.
- [22] D. L. Chaum, “Untraceable Electronic Mail, Return Addresses, and Digital Pseudonyms,” *Communications of the ACM*, vol. 24, no. 2, pp. 84-90, 1981.
- [23] B. Chor, O. Goldreich, E. Kushilevitz, and M. Sudan, “Private Information Retrieval,” *FOCS*, pp. 41-50, 1995.
- [24] S. Angel, H. Chen, K. Laine, and S. Setty, “PIR with Compressed Queries and Amortized Query Processing,” *IEEE Symposium on Security and Privacy*, pp. 962-979, 2018.
- [25] C. Dwork, “Differential Privacy,” *ICALP*, pp. 1-12, 2006.
- [26] M. Marlinspike and T. Perrin, “The X3DH Key Agreement Protocol,” *Open Whisper Systems*, 2016.
- [27] D. Dasgupta, A. Roy, and A. Nag, “Multi-Factor Authentication,” *Advances in User Authentication*, pp. 185-233, Springer, 2017.
- [28] K. Lee et al., “An Empirical Study of Wireless Carrier Authentication for SIM Swaps,” *ACM CCS*, pp. 61-78, 2020.
- [29] T. Engel, “SS7: Locate. Track. Manipulate,” *31st Chaos Communication Congress*, 2017.
- [30] U.S. Securities and Exchange Commission, “Electronic Storage of Broker-Dealer Records,” *17 CFR 240.17a-4*, 2003.
- [31] P. Voigt and A. von dem Bussche, “The EU General Data Protection Regulation (GDPR),” Springer, 2017.
- [32] E. W. T. Ngai, Y. Hu, Y. H. Wong, Y. Chen, and X. Sun, “The Application of Data Mining Techniques in Financial Fraud Detection: A Classification Framework and an

- Academic Review of Literature,” *Decision Support Systems*, vol. 50, no. 3, pp. 559-569, 2011.
- [33] Federal Bureau of Investigation, “Internet Crime Report 2020,” IC3, 2020.
 - [34] A. P. Felt, R. W. Reeder, A. Ainslie, H. Harris, M. Walker, C. Thompson, M. E. Acer, E. Morant, and S. Consolvo, “Rethinking Connection Security Indicators,” *SOUPS*, pp. 1-14, 2015.
 - [35] B. Laurie, A. Langley, and E. Kasper, “Certificate Transparency,” *RFC 6962*, 2013.
 - [36] P. R. Zimmermann, *The Official PGP User’s Guide*, MIT Press, 1995.
 - [37] C. Fromknecht, D. Velicanu, and S. Yakoubov, “Certcoin: A Namecoin Based Decentralized Authentication System,” *MIT CSAIL Technical Report*, 2014.
 - [38] L. Ducas et al., “CRYSTALS-Dilithium: A Lattice-Based Digital Signature Scheme,” *TCHES*, vol. 2018, no. 1, pp. 238-268, 2018.
 - [39] H. Abelson et al., “Keys Under Doormats: Mandating Insecurity by Requiring Government Access to All Data and Communications,” *Journal of Cybersecurity*, vol. 1, no. 1, pp. 69-79, 2015.
 - [40] S. Nakamoto, “Bitcoin: A Peer-to-Peer Electronic Cash System,” 2008.